Audit complet de la mise à niveau d'EP Manager et des modules syllabus

Sébastien Lefebvre

Novembre 2026 – mod_ep 1.0.6, mod_epsynthesis 1.0.3, modules syllabus 1.5.1

1 Objet et méthode

L'audit porte sur l'ensemble de la branche de mise à niveau, avant sa fusion : les cinq modules d'activité (`mod_ep`, `mod_epsynthesis`, `mod_syllabus`, `mod_syllabusstaff`, `mod_syllabusstudent`, environ 45 000 lignes de PHP), leur liaison avec `mod_stage`, leurs tests, la CI et la documentation. Il complète les rapports de charge, de concurrence et de bout en bout déjà présents dans `docs/audit`, sans en reprendre les mesures.

Six revues du code , menées en parallèle, chacune sur tout le périmètre de son domaine, en lecture seule, chaque constat tracé dans le code de bout en bout :

1. sécurité de `mod_ep` et `mod_epsynthesis` (droits par page et par action, identifiants de la requête, clé de session, échappement, fichiers, imports) ;
2. sécurité des modules syllabus (mêmes points, plus l'anonymat des avis et les actions du suivi sur les modules d'autres cours) ;
3. intégrité des données (schéma et mises à jour, suppression, réinitialisation, sauvegarde et restauration, RGPD, concurrence, tâches planifiées) ;
4. performance et portabilité SQL (PostgreSQL, MariaDB/MySQL, SQL Server, Oracle) ;
5. langues, accessibilité et cohérence de l'interface ;
6. tests, CI, métadonnées de version et cohérence de la documentation.

Chaque constat retenu a ensuite été revérifié dans le code ; les défauts confirmés et de portée limitée sont corrigés, avec un test qui échoue sans la correction quand c'est possible. Les autres sont décrits en section 5, avec la raison pour laquelle ils restent.

Contrôles sur le banc (Moodle 4.5, PHP 8.3, PostgreSQL 16, jeu de données de 1 000 étudiants) : schéma de la base comparé aux fichiers `install.xml` après les mises à jour successives, test de conformité RGPD du cœur, balayage dynamique des droits (`docs/audit/banc/balayage_droits.py`, nouveau), scénario de bout en bout des modules syllabus rejoué avec le code corrigé.

2 Synthèse

Domaine	Constats	Corrigés	Restants
Sécurité	14	8	6
Intégrité des données	15	9	6
Performance et portabilité	7	5	2
Langues et accessibilité	8	4	4
Tests, CI et documentation	7	2	5
Total	**51**	**28**	**23**

Un constat peut regrouper plusieurs points de même nature (par exemple trois écarts de portabilité SQL, ou les tableaux sans conteneur défilant de cinq pages).

Aucun constat critique. Les plus graves, tous corrigés :

— un compte qui voit tous les dossiers d'une activité EP (la DEVE) pouvait lire le supplément au diplôme – nom, numéro, date de naissance – de n'importe quel compte du site, en changeant l'identifiant dans l'adresse ; reproduit sur le banc avant correction ;

— un étudiant pouvait faire sauter l'étape DEVE d'une déclaration en changeant son type ;

— un responsable pouvait lire les avis avant la fin du recueil (fermeture puis réouverture de la fenêtre), et l'heure de chaque avis, dans le journal, permettait de retrouver son auteur en comparant les résultats ;

— une restauration rendait invérifiables les suppléments déjà remis aux étudiants.

Les constats restants sont de gravité moyenne ou basse ; deux recommandations de gravité haute concernent la CI (mise à jour depuis la version en production, scénarios Behat de `mod_ep`).

3 Contrôles automatiques

Contrôle	**Résultat**
Schéma de la base du banc, mis à jour version après version, comparé aux `install.xml` (`check_database_schema.php`)	conforme
Test de conformité RGPD du cœur (fournisseurs des cinq modules compris)	1 648 tests réussis
Tests unitaires des cinq modules (132 + 8 + 43 + 6 + 1), après corrections	190 réussis
Scénarios Behat des modules syllabus	6 scénarios, 102 étapes
Style Moodle (`phpcs`), PHPDoc, validation, points de mise à jour (CI)	sans remarque
Scénario de bout en bout des modules syllabus, code corrigé	51/51 contrôles
Balayage des droits : 59 pages × 3 comptes	177 appels, 27 ouvertures attendues

Balayage des droits. Chaque page des cinq modules est appelée avec l'identifiant d'une activité par trois comptes : un étudiant d'une autre promotion (non inscrit), un étudiant inscrit, le responsable d'un autre module. Les 27 pages qui ne refusent pas sont toutes légitimes : pages de l'étudiant (vue, catalogue, déclaration, son supplément, ses éléments, sa fiche de module en PDF, « Mes modules »), vérification publique d'un supplément par son code, pages des enseignants du cours (tableau de pilotage, validation, propositions, matrice et progression ouvertes aux enseignants), page des compétences d'un module en lecture seule. Le balayage ne fait que des requêtes de consultation : les actions sont couvertes par les tests unitaires et la revue du code.

4 Constats corrigés

4.1 Sécurité

Gravité	Constat	Correction
MOYENNE	`supplement.php` et `dashboard.php` : l'identifiant d'étudiant de l'adresse n'était pas contrôlé ; un détenteur de `mod/ep:viewall` lisait le supplément (PDF avec date de naissance) ou la situation de tout compte du site.	Contrôle de l'inscription à l'activité, comme à l'émission. Banc : PDF obtenu avant, « Invalid user ID » après.
MOYENNE	Déclaration en attente : le type changeait, pas l'étape en attente ; le référent tranchait un type que seule la DEVE valide.	Étape recalculée sur le circuit du nouveau type (test `test_type_change_follows_new_flow`).
HAUTE	Avis : un responsable fixait librement la fenêtre ; il pouvait la fermer pour lire les résultats, la rouvrir, ou ouvrir dans une autre année pour archiver le recueil en cours.	Dès le premier avis, seule la DEVE déplace la fenêtre, par la page du recueil comme par les paramètres de l'activité (test `test_window_locked_after_first_response`).
HAUTE	Avis : l'événement d'envoi gardait l'auteur et l'heure ; rapproché de l'évolution des résultats, il désignait l'auteur de chaque avis.	Événement anonyme : le journal ne le montre qu'aux administrateurs (`moodle/site:viewanonymousevents`).
MOYENNE	Résultats comparés du suivi : seul le droit du suivi était vérifié, pas celui de chaque module.	Modules filtrés sur `mod/syllabus:manage`, comme la liste et la relecture.
BASSE	Libellés des listes déroulantes (nom et numéro d'étudiant, code de compétence, période) non échappés : `html_writer::select()` ne le fait pas.	`s()` sur ces libellés.
BASSE	Exports CSV : une cellule commençant par `=`, `+`, `-` ou `@` s'exécutait comme formule dans un tableur ; le cœur ne le neutralise que dans ses versions récentes.	Apostrophe ajoutée à ces cellules dans les 15 lignes d'export des deux modules.
MOYENNE	Suppressions de questions, types, référentiels et compétences confirmées en JavaScript seulement : sans JavaScript, un clic supprimait.	Page de confirmation du serveur comme dans `mod_ep` (`syllabus_require_confirmation()`).

4.2 Intégrité des données

Gravité	Constat	Correction
HAUTE	Restauration : le sceau des suppléments n'était pas sauvegardé ; après suppression et restauration d'une activité (corbeille), les diplômes remis étaient déclarés « non reconnus ».	Sceau sauvegardé ; sur le même site, s'il est authentique et que le numéro d'origine est libre, il est recalculé ; toute autre copie reste non reconnue (deux tests).
MOYENNE	Restauration : les décisions d'un crédit écarté étaient rattachées au crédit restauré juste avant.	`SKIP_ALL_CHILDREN`.
MOYENNE	Rentrée appliquée deux fois depuis deux onglets ou par un envoi répété (année N vers N+2).	Mise à jour conditionnée à l'année de départ confirmée (test).

Gravité	Constat	Correction
MOYENNE	Transfert d'un étudiant : ses crédits de stage étaient supprimés comme orphelins par la synchronisation de la cible.	Convertis en saisies DEVE si la cible ne lit pas les mêmes stages, laissés à sa synchronisation sinon (test).
MOYENNE	Suppression d'un EP du catalogue : versions du syllabus, séances et prérequis restaient orphelins ; le contrôle des inscriptions n'était pas sous verrou ; le bouton échouait toujours (clé de session absente du lien).	`ep_delete_activity()` sous verrou et en transaction ; page de confirmation (test).
MOYENNE	Émission groupée des suppléments : une erreur faisait relancer toute la tâche, qui réémettait les suppléments déjà émis (nouveaux numéros).	Un étudiant en échec n'arrête pas les autres ; ceux dont le supplément a été émis depuis la demande sont sautés (test).
BASSE	Copie d'un cours sans données utilisateurs : la fenêtre des avis gardait les anciennes dates ; les étudiants du nouveau cours étaient prévenus d'un recueil passé.	Recueil sans fenêtre après une telle copie (test).
BASSE	Tâche d'ouverture des avis : un arrêt en cours d'envoi renvoyait tous les messages du module.	Module marqué avant l'envoi.
BASSE	Transfert : le second verrou était pris hors du bloc qui libère le premier.	Pris dans le bloc.

4.3 Performance et portabilité

Gravité	Constat	Correction
HAUTE	Intitulé des crédits de stage sans troncature (thème et structure jusqu'à 255 caractères chacun) : l'insertion échouait, et avec elle chaque page qui synchronise.	Borné à 255 caractères (test) ; rédigé dans la langue du site, pour qu'une consultation dans une autre langue ne réécrive pas tous les crédits.
MOYENNE	Décisions en lot : les courriels partaient pendant que le verrou de l'activité était pris (20 à 60 s pour une promotion).	Messages gardés puis envoyés après validation et libération du verrou ; rien n'est envoyé si le lot échoue (test).
MOYENNE	Tâche d'ouverture des avis : une requête par étudiant.	Une requête par module.
MOYENNE	`AVG` sur un entier : moyenne tronquée sous SQL Server.	Moyenne décimale.
BASSE	`DISTINCT` sur la fiche utilisateur (champs texte, refusé par Oracle) ; `<> ""` (Oracle) ; alias `uid` (réservé sous Oracle).	Sous-requête, `sql_isnotempty()`, alias `userid`.

4.4 Langues, accessibilité, documentation

— Listes de filtres : le nom lu par les lecteurs d'écran était le nom technique du paramètre (« status ») ; c'est désormais le libellé de la liste.

— Cases à cocher des responsables d'un EP et des activités liées à une synthèse nommées ; indicateurs d'étape (coche, cercle) doublés d'un texte « Fait » / « À faire ».

— Tableaux larges (gabarit commun de `mod_ep`, liste des modules, résultats, catalogue, synthèse) dans un conteneur défilant : la page ne défile plus en largeur sur téléphone.

— Chaînes absentes du cœur 4.5 (`nonewmodules`, `cannotcreatezip`) remplacées : elles s'affichaient entre crochets.

— README et INSTALL au vocabulaire « Avis des étudiants » ; règle de la fenêtre et anonymat du journal documentés ; guides au numéro des modules (guide syllabus 1.7).

— `\$plugin->supported = [403, 405]` dans les cinq modules ; CHANGELOG corrigé sur la datation des versions et complété ; trois fichiers de tests rendus exécutables seuls.

5 Constats restants et recommandations

5.1 Recommandations prioritaires

CI : mise à jour depuis la version en production (HAUTE). La CI n'installe qu'à neuf ; la conversion des données des sites en 0.1.0 n'a été vérifiée que sur le banc (`migration_avant.php`, `migration_apres.php`). Ajouter un job qui installe `main`, crée des données, passe au code de la branche, lance la mise à jour et rejoue les contrôles.

Behat de `mod_ep` (HAUTE). Aucun scénario pour les 43 pages de `mod_ep`, alors que le CHANGELOG 0.2.0 en annonce. Le balayage des droits du banc couvre la consultation ; trois scénarios sont recommandés : justificatif d'un autre étudiant refusé, supplément émis visible du seul étudiant et de la DEVE, pages DEVE refusées à un enseignant.

Réglages communs des avis (MOYENNE). Seuil d'anonymat, résultats des enseignants, relecture et questions communes valent pour tout le site, mais se règlent depuis n'importe quelle activité de suivi. C'est le choix demandé (tout depuis le suivi, sans l'administration du site) ; il suppose de ne donner `mod/syllabusstaff:manageall` qu'à la DEVE et de garder un seuil d'au moins 3. Une capacité au niveau du site est possible si plusieurs services gèrent des catégories distinctes.

Anonymat en base (MOYENNE, risque résiduel). Participation et réponse sont insérées l'une après l'autre : leurs identifiants séquentiels se correspondent, en base et dans une sauvegarde avec données utilisateurs. Aucune page ni aucun export ne les relie ; le risque est documenté dans l'INSTALL : accès à la base et aux sauvegardes restreint. Découpler l'ordre (réponses insérées par lots mélangés) demanderait une file d'attente.

5.2 Autres constats, sans correction

Gravité	Constat	Raison, recommandation
MOYENNE	Restauration d'une archive globale dans une instance liée aux mêmes stages : ECTS de stage comptés deux fois (plausible).	Cas rare (remise à zéro puis restauration) ; écarter les crédits de stage dans ce cas.
MOYENNE	Oracle : colonnes `comment`, `number`, `level`, mots réservés.	Oracle n'est ni visé ni testé ; les renommer est un changement de schéma, à faire seulement si Oracle devient une cible.
BASSE	Responsables : tout responsable désigne ou retire des co-responsables ; dans un module sans responsable, un enseignant peut se désigner.	Conforme au guide ; la DEVE voit les responsables dans la liste des modules.
BASSE	Progression, livret : modules de cours masqués visibles aux enseignants du suivi.	Filtrer sur la visibilité du cours si des cours en préparation doivent rester discrets.
BASSE	Effacement RGPD d'un étudiant : il peut redonner son avis la même année.	Effacement rare et en fin de parcours ; documenté.
BASSE	Imports : responsables et validateurs reconnus sur tout le site.	Aucun gain de droits ; limiter aux enseignants du cours si besoin.

Gravité	Constat	Raison, recommandation
BASSE	Concurrences sans corruption : double décision d'année (erreur d'index unique), deux brouillons de syllabus de même numéro, création simultanée du secret du sceau.	Cas improbables ; verrouiller si observés.
BASSE	Relances fondées sur la date de création de la demande ; DEVE non inscrite au cours jamais relancée.	Inscrire la DEVE au cours (recommandé par l'INSTALL).
BASSE	Réglage du premier mois de l'année changé en cours d'année : le recueil suivant archive le précédent.	Ne changer ce réglage qu'entre deux années ; documenté.
BASSE	Liens de compétences des cours sans module absents des sauvegardes de cours ; périmètre de catégorie restauré sur un autre site.	À refaire après une copie d'un site à l'autre.
BASSE	Réinitialisation : empreinte de synchronisation des stages gardée (crédits de stage recalculés au plus tard à la tâche de nuit) ; suppression par sous-requête lente sous MariaDB pour de très gros volumes.	Sans conséquence fonctionnelle.
BASSE	Livrets : deux premiers téléchargements simultanés produisent tous deux le PDF ; renommage d'un responsable visible le lendemain ; archive ZIP des suppléments lue fichier par fichier.	Coût mesuré acceptable (rapports de charge).
BASSE	Messages rédigés dans la langue de l'expéditeur ou du site, non du destinataire.	Site monolingue ; à revoir pour un site bilingue.
BASSE	Accessibilité : pas de légende ni d'en-tête de ligne dans les tableaux, sens de tri sans `aria-sort`, niveaux de titres sautés, actions de ligne sans contexte.	Lisible au lecteur d'écran ; à reprendre avec une revue RGAA.
BASSE	Langues : concaténations avec « : » codé en dur, « DEVE » et « academic office » mêlés en anglais, descriptions d'événements de `mod_ep` et traces des tâches en français, 19 chaînes inutilisées.	Sans effet en français ; à harmoniser avec la traduction anglaise.
BASSE	Retrait de fenêtre en lot confirmé en JavaScript seulement.	Retrait réversible (la fenêtre se refixe), réponses conservées.
MOYENNE	CI : dépôt StageCompagnon pris sur `main` sans épinglage, outils non épinglés, ni PHP 8.3, ni MySQL, ni SQL Server ; seuil de couverture absent.	Épingler un commit de StageCompagnon et ajouter une ligne PHP 8.3 lors d'une prochaine révision de la CI.
BASSE	Tests : quelques assertions faibles (exception générique, crédit préexistant non vérifié) ; test annuel sensible à la minute qui suit le 1er septembre.	Probabilité très faible ; à resserrer au fil de l'eau.
BASSE	Banc : prérequis (Python `requests`, Playwright, `pdftoppm`) et en-têtes GPL des scripts ; traduction française minimale des guides sans attribution.	Prérequis d'exécution précisés dans le README du banc ; le reste à compléter.

6 Conclusion

Les contrôles de base sont solides et uniformes : chaque page exige la connexion au cours et un droit dans le bon contexte, toutes les écritures passent par la clé de session, tout le SQL est paramétré, l'échappement est cohérent, aucun service web ni code JavaScript n'est exposé. Les défauts trouvés tenaient à des chemins secondaires – un identifiant de la requête non relié à l'activité, un champ non recalculé, une donnée non sauvegardée – et à l'anonymat des avis face aux traces indirectes (journal, ouverture et fermeture de la fenêtre).

Les 28 corrections sont couvertes par 7 tests unitaires de plus (190 au total), le balayage des droits et le scénario de bout en bout rejoués sur le banc. La branche peut être fusionnée ; les deux recommandations de CI (mise à jour depuis la version en production, Behat de `mod_ep`) sont à traiter ensuite, avant la prochaine évolution du schéma.